

Thesis Threat Model Report — Scenario 3

LLM-Integrated Account Recovery and Profile Management System | Multi-Framework Audited Threat Dataset

117 RAW FINDINGS	8 VALIDATED THREATS	109 DUPLICATES EXCLUDED	100.0% GROUNDING RATE	6.8% THREAT PRECISION
---------------------	------------------------	----------------------------	--------------------------	--------------------------

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T3.01	P2 — Account Recovery Service DF8: Recovery Token Submission / DF9: Forwarded Token Credential	Spoofing	ATT&CK: T1110.001: Password Guessing / Token Guessing OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Identifiability ML Sec: –	Recovery token brute-forcing: Attacker submits automated token guesses via DF8/DF9 to hijack victim accounts during active recovery windows. Evidence: P2 validates submitted recovery credentials (DF9) against DS2. Weak entropy or unthrottled verification allows brute-forcing.	Generate high-entropy tokens (>= 128 bits CSPRNG), enforce strict attempt throttling (e.g., 5 attempts max), and invalidate token upon repeated failures.	9.1 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	Design
T3.02	P2 — Account Recovery Service DF12: Token Invalidation / Consumption Request	Tampering	ATT&CK: T1552: Unsecured Credentials (Token Replay) OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Linkability & Non-repudiation ML Sec: –	Recovery token replay: P2 fails to atomically consume/invalidate recovery tokens in DS2 (DF12) upon first use, enabling an attacker to reuse intercepted tokens. Evidence: Workflow step 15 requires: 'A valid recovery token is consumed or invalidated so that it cannot be reused.' Flaws in invalidation logic permit replay.	Enforce atomic, single-use token consumption within the same database transaction that validates the recovery credential.	9.1 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	Implementation
T3.03	P2 — Account Recovery Service DF1: Recovery Initiation Request / DF7: Recovery Challenge	Information Disclosure	ATT&CK: T1589.002: Email Addresses OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Detectability & Identifiability ML Sec: –	Account recovery user enumeration: Differential response messages or timing on DF7 reveal whether an account exists in DS1. Evidence: P2 queries DS1 (DF3/DF4) and returns recovery challenges (DF7). Explicit requirement mandates addressing recovery-request enumeration.	Return uniform generic responses ('If the account exists, recovery instructions have been dispatched') with standardized execution timing.	5.3 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Design
T3.04	P3 — Profile Management Service DF13: Authorized Profile Update Request / DF14: Profile Modification Query	Elevation of Privilege	ATT&CK: T1078: Valid Accounts (Mass Assignment) OWASP: A01:2021 – Broken Access Control ATLAS: – LLM Top10: – LINDDUN: Non-compliance ML Sec: –	Mass assignment / parameter tampering on profile update: Attacker submits unauthorized attributes (e.g. `role: admin`, `status: verified`) in profile update payload. Evidence: Workflow step 18 requires: 'The request must contain only the profile changes that the recovered/authorized user is permitted to make.'	Enforce strict schema whitelisting for permitted profile modification fields, rejecting any administrative or internal attributes.	8.1 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	Implementation
T3.05	DF20 — Support Prompt + Approved Context DF20: Support Prompt + Approved Context -> P5 / DF21: Outbound Prompt Request -> EE2	Information Disclosure	ATT&CK: T1552: Unsecured Credentials OWASP: A01:2021 – Broken Access Control ATLAS: AML.T0024: LLM Data Leakage LLM Top10: LLM06: Sensitive Information Disclosure LINDDUN: Disclosure of Information ML Sec: ML09: Model Data Leakage	Leakage of recovery secrets to external LLM: P4/P5 includes raw recovery tokens, temporary passwords, or reset secrets in the prompt sent across Zone D. Evidence: Explicit requirement mandates: 'The AI assistant must not receive raw recovery tokens, passwords, password-reset secrets, or unnecessary sensitive authentication material.'	Architecturally isolate P4 from recovery secret data and enforce automated regex-based secret redaction on all outgoing prompt payloads.	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	Design

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T3.06	P4 — AI Account Support Assistant DF18: User Account Question / DF24: Generated AI Answer	Elevation of Privilege	ATT&CK: T1059: Command and Scripting Interpreter OWASP: A04:2021 – Insecure Design ATLAS: AML.T0054: LLM Output Manipulation LLM Top10: LLM06: Excessive Agency / Insecure Output Handling LINDDUN: Non-compliance ML Sec: ML01: Adversarial Robustness	Excessive trust in LLM output: Attacker uses prompt injection to trick LLM into generating fake authorization instructions that downstream components treat as valid recovery decisions. Evidence: Explicit constraint: 'The generated LLM response is untrusted output and must not directly trigger account recovery, profile modification, token creation, authorization, or authentication decisions.'	Ensure LLM responses are treated strictly as untrusted text, and never allow LLM output to directly invoke or authorize state-modifying operations.	9.1 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	Design
T3.07	DS2 — Recovery Token Storage DF5: Store Recovery Token Request / DF10: Token Validation Query	Information Disclosure	ATT&CK: T1552.001: Credentials in Files / Databases OWASP: A02:2021 – Cryptographic Failures ATLAS: – LLM Top10: – LINDDUN: Disclosure of Information ML Sec: –	Storage of plaintext recovery tokens in DS2: Unauthorized read access to token storage allows an attacker to compromise all active recovery tokens across the application. Evidence: DS2 stores active recovery tokens, expiration, and state. Requirement addresses token-storage compromise.	Store recovery tokens as salted cryptographic hashes (e.g. SHA-256) in DS2, verifying hashes in constant time during validation.	4.9 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	Implementation
T3.08	P2 — Account Recovery Service DF1: Recovery Initiation Request / DF2: Forwarded Recovery Request	Denial of Service	ATT&CK: T1499: Endpoint Denial of Service OWASP: A05:2021 – Security Misconfiguration ATLAS: – LLM Top10: – LINDDUN: Unawareness ML Sec: –	High-volume automated recovery initiation requests exhaust notification provider quotas (SMS/Email) and server queues, denying recovery services to legitimate users. Evidence: P2 processes recovery requests from Zone A. Requirement explicitly dictates protection against denial of service and resource exhaustion.	Implement per-IP and per-account rate limits, CAPTCHA on recovery initiation, and multi-tier notification provider fallbacks.	7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	Implementation